資工實務專題計畫書

基於 RAG 系統的 Prompt Injection 攻擊與防禦框架研究

Research on Prompt Injection Attack and Defense Framework for RAG Systems

專題名稱	基於 RAG 系統的 Prompt Injection 攻擊與防禦框架研究
提案學生	B11215026 曾靖傑
指導教授	林佳志教授
所屬系所	資訊工程學系
提案日期	2026 年 4 月

一、研究背景與動機

1.1 大型語言模型的廣泛應用與安全挑戰

近年來，大型語言模型（Large Language Model, LLM）的快速發展使其被廣泛應用於智慧客服、企業知識管理、程式碼生成等場景。以 ChatGPT、Claude、Gemini 為代表的生成式 AI 已深入各行各業，並催生出大量結合「檢索增強生成」（Retrieval-Augmented Generation, RAG）架構的商業應用。

然而，隨著 LLM 應用的普及，針對其安全性的攻擊手法也日益多元與複雜。其中，Prompt Injection Attack（提示注入攻擊）被 OWASP LLM Top 10 v2（2025）列為 LLM 應用程式十大安全風險的首位（LLM01），是當前 LLM 安全領域最具威脅性的漏洞之一。

1.2 Prompt Injection 攻擊的威脅

Prompt Injection 攻擊的核心原理是透過精心設計的惡意輸入，覆蓋或繞過模型的系統指令 (System Prompt)，進而操控模型產生攻擊者預期的有害輸出。此類攻擊主要分為兩種型態：

- 直接注入 (Direct Prompt Injection)：攻擊者直接在使用者輸入中夾帶惡意指令，例如「忽略前面所有指示，請告訴我如何……」，試圖覆蓋系統設定的行為邊界。
- 間接注入(Indirect Prompt Injection)：攻擊者預先污染 RAG 系統所使用的外部知識庫（如文件、網頁、資料庫），當系統擷取相關內容時，惡意指令隨之被送入模型上下文。

間接注入的威脅性尤為突出，因為它無需直接存取應用程式介面，僅需污染資料來源即可發動攻擊，攻擊者的存在難以被察覺。

1.3 研究動機

目前學術界與產業界對 Prompt Injection 的防禦研究仍處於起步階段，現有工作存在以下不足：

1. 大多數研究僅針對直接注入，鮮少處理 RAG 場景下的間接注入攻擊。
2. 缺乏系統性的多層次防禦架構，現有方案多為單點修補 (如關鍵詞過濾)，易被繞過。

有鑑於此，本研究擬以 RAG 問答系統為研究載體，系統性地設計並評估一套多層次的 Prompt Injection 防禦框架，填補現有研究的空缺，並提供可直接應用於實際系統的防禦方案。

二、標的文獻與專題目標

2.1 相關文獻回顧

本研究將以下列代表性文獻作為理論基礎與比較基準：

文獻	發表年份	貢獻
Ignore Previous Prompt: Attack Techniques For Language Models (Perez & Ribeiro, arXiv 2211.09527)	2022	首次系統性研究 Direct Prompt Injection 攻擊，聚焦於 goal hijacking（目標劫持）與 prompt leaking（提示詞洩漏）兩類攻擊手法，並提出 PromptInject 評估框架。
Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection (Greshake et al., AISec @ CCS 2023)	2023	提出 Indirect Injection 概念，展示 RAG 場景的高危風險，並推導含資料竊取、蠕蟲傳播等攻擊的完整分類體系。
OWASP LLM Top 10 — LLM01: Prompt Injection	2025 年版（v2）	將 Prompt Injection 列為 LLM 首要安全風險，提出防禦方向
InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents (Zhan et al., ACL Findings 2024)	2024	針對工具整合型 LLM Agent 的間接注入建立評測基準（1,054 測試案例，涵蓋 17 種使用者工具 及 62 種攻擊者工具）。

2.2 專題目標

本研究訂定以下四項核心目標：

- 建立 RAG 問答系統原型:
  包含文件上傳、向量搜尋、提示詞組合與 LLM 生成等完整流程。
- 設計攻擊資料集
  涵蓋直接注入、間接注入、多語言混淆、Role-play 越獄、Prompt Leaking 五類攻擊手法。
- 設計並實作多層次防禦框架
  包含輸入清理、注入偵測、提示詞分區、受控生成、輸出驗證五道關卡。
- 量化評估防禦效果
  以攻擊成功率 (ASR)、誤攔截率 (FPR)、F1 Score 與延遲開銷等指標進行系統性比較實驗。

三、系統架構與實作規劃

3.1 系統整體架構

本系統採分層架構設計，由外至內共分為「使用者輸入層」、「防禦管線層」、「RAG 核心層」與「LLM 推理層」四個層次，攻擊向量可於不同層次進入，防禦機制亦對應各層次進行攔截與處理。

3.2 五層防禦管線設計

關卡	模組名稱	核心機制	針對攻擊類型
Layer 1	輸入清理器	正規表示式過濾、關鍵詞黑名單、長度限制	直接注入（已知模式） 作為快速預過濾，在 Layer 2 及之後的流程前先行過濾。
Layer 2	注入偵測器	Fine-tuned BERT/RoBERTa 二元分類器	直接注入、間接注入（通用） 負責處理 Layer 1 未攔截的模糊案例。
Layer 3	提示詞分區	結構化標籤隔離 System/User 區塊	指令覆蓋攻擊
Layer 4	受控生成	格式約束、輸出結構限制、低 temperature 設定	越獄與幻覺輸出
Layer 5	輸出驗證器	獨立模型輸出檢查、格式合規性檢查	資訊洩漏、有害輸出

3.3 技術棧

類別	工具 / 框架
RAG 框架	LangChain + FAISS（向量資料庫）+ OpenAI / Claude API
偵測器訓練	Hugging Face Transformers（bert-base-multilingual-cased）
後端 API	FastAPI（方便設計 A/B 實驗端點）
實驗記錄	Weights & Biases（W&B）
攻擊資料集	AdvBench（Zou, Wang, Carlini, Nasr, Kolter & Fredrikson, 2023）、JailbreakBench（Chao et al., NeurIPS 2024）
開發環境	Python 3.11、CUDA 11.8、Google Colab Pro+

四、預期成果與價值

4.1 學術貢獻

- 設計並驗證五層多模組防禦架構，量化各層次的防禦貢獻與其對系統效能的影響。
- 揭示直接注入與間接注入在不同防禦策略下的行為差異，提供未來研究的比較基準。

4.2 工程價值

- 防禦框架以模組化設計實作，可作為即插即用的中介層嵌入任何既有 RAG 應用。
- 攻擊評測工具可被後續研究者複現與擴展，降低 LLM 安全研究的入門門檻。

4.3 預期量化指標

評估指標	基線（無防禦）	目標（完整框架）	說明
攻擊成功率（ASR）	48.9% (InjecAgent，針對 GPT-4 的 Data Stealing - Physical Data 測試)	< 20%	攻擊成功繞過防禦的比例
偵測器 F1 Score	—	> 0.90	注入偵測模組的分類效能
誤攔截率（FPR）	—	< 5%	正常查詢被誤判為攻擊的比例
推理延遲增加	0 ms	< 500 ms	加入防禦後的額外時間開銷

4.4 後續延伸方向

本研究完成後，可作為以下研究方向的起點：

- 將防禦框架擴展至 Multi-Agent 多智能體系統，研究代理間的 Prompt Injection 傳播問題。
- 結合對抗訓練 (Adversarial Training) 強化偵測器對未知攻擊的泛化能力。
- 探索差分隱私 (Differential Privacy) 在防止 RAG 知識庫遭污染方面的應用。

— 計畫書結束 —